

Mount Kenya University

Unlocking Infinite Possibilities

Student Name	Eddy Kering
Admission Number	BSCCS/2024/61947
Course	Bachelor of Science in Computer Science
Unit Code	BIT4139
Unit Name	Ethical Hacking and Counter measures
Lecturer	Michael Nyoro
Semester / Year	2026

Table of Contents

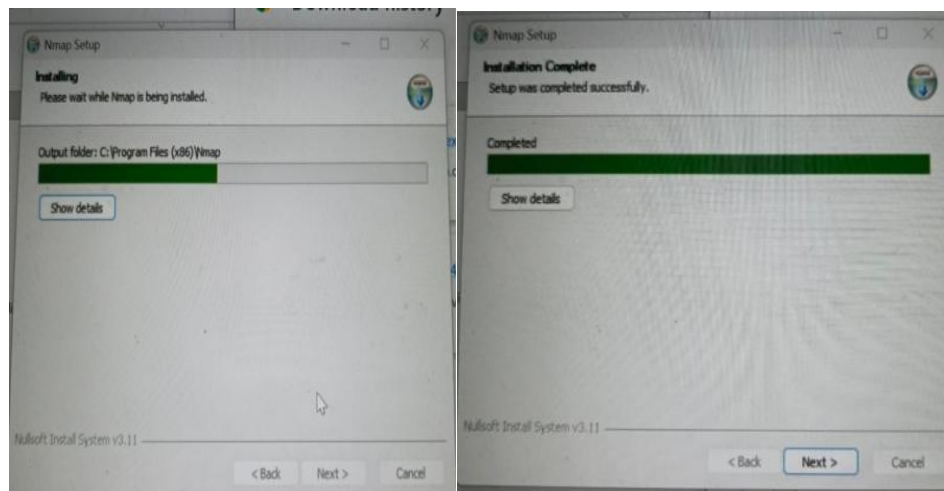
Week 1: Network Scanning with Nmap	3
1.1 Tool Installation	3
1.2 Open Ports Scan	3
1.3 Vulnerability Test	4
1.4 Footprinting (OS and Service Detection)	4
Week 2: Advanced Nmap Scanning Techniques	6
2.1 Scan Ports	6
2.2 Identify OS Version	6
2.3 Detect Running Services	7
2.4 Enumerate Users and Shared Folders	7
2.5 Detect Vulnerabilities	7
Week 3: Passive OSINT Reconnaissance — Safaricom PLC	9
3.1 Introduction	9
3.2 Summary of Findings	9
3.3 Domain and Registrar Information	9
3.4 IP Address Information	10
3.5 Subdomain Discovery	10
3.6 Open Services (Shodan.io)	11
3.7 Email Patterns	11
3.8 Leaked Credentials (IntelligenceX)	12
3.9 Technology Stack (Wappalyzer)	12
3.10 Security Recommendations	13

Week 1: Network Scanning with Nmap

Date	May 21, 2026
Tool Used	Nmap (Network Mapper) — Zenmap GUI
Target	192.168.0.101 (Local Network Host)
Objective	Install Nmap and perform open port scanning on a local host

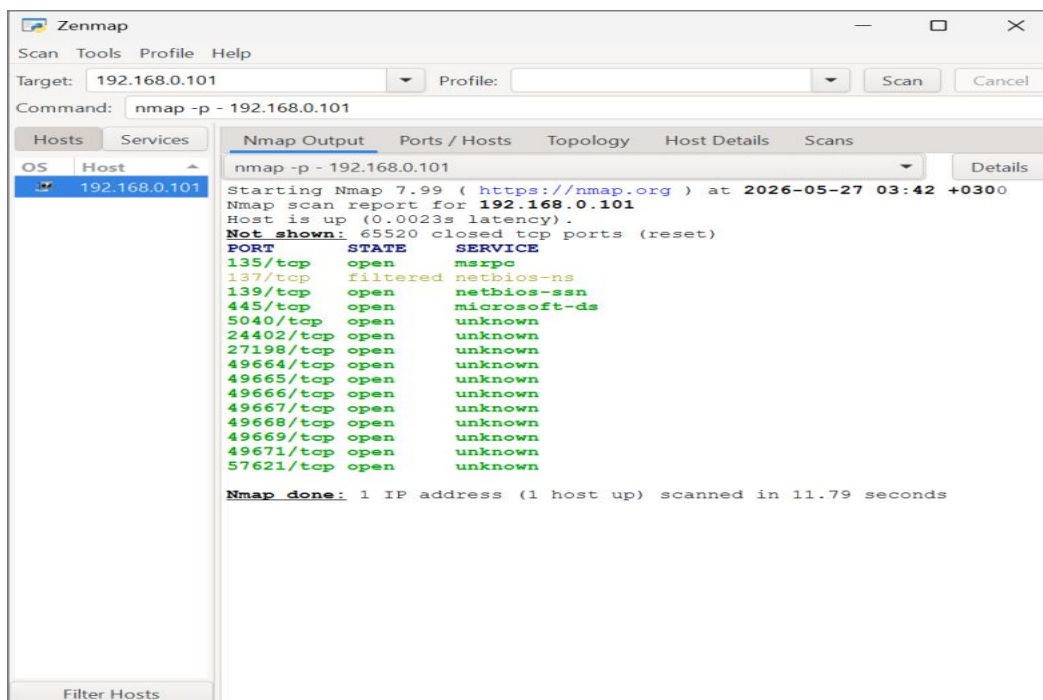
1.1 Tool Installation

Nmap was downloaded from the official website (nmap.org) and installed on a Windows system. The Zenmap graphical interface was installed alongside the command-line version for ease of use. Installation was completed successfully with output folder configured to C:\Program Files (x86)\Nmap.



1.2 Open Ports Scan

A full port scan was conducted on the target host 192.168.0.101 using the command `nmap -p - 192.168.0.101` to scan all 65,535 TCP ports. The scan completed in 11.79 seconds.

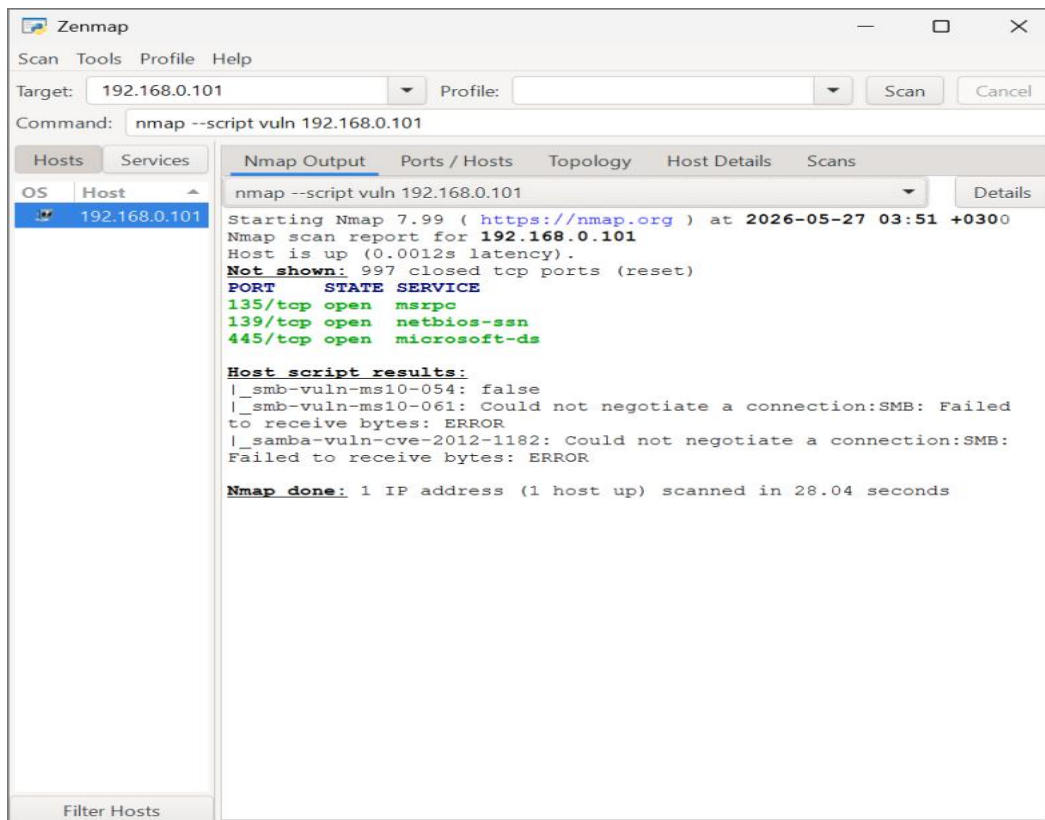


Ports discovered on 192.168.0.101:

Port / Protocol	State	Service
135/tcp	open	msrpc
137/tcp	filtered	netbios-ns
139/tcp	open	netbios-ssn
445/tcp	open	microsoft-ds
5040/tcp	open	unknown
24402/tcp	open	unknown
27198/tcp	open	unknown
49664–49669/tcp	open	unknown
49671/tcp	open	unknown
57621/tcp	open	unknown

1.3 Vulnerability Test

A vulnerability scan was performed using Nmap's scripting engine with the command `nmap --script vuln 192.168.0.101`. This ran known CVE detection scripts against the open ports.

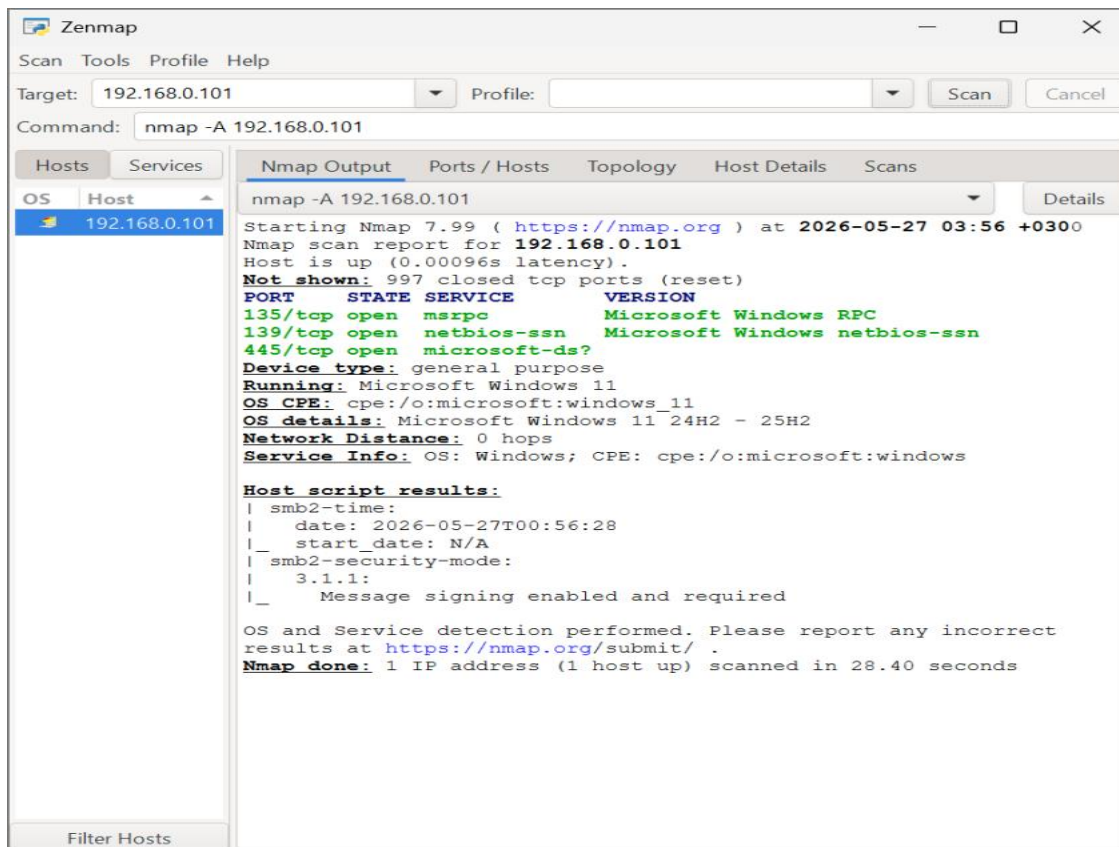


Script	Result
smb-vuln-ms10-054	false — Not vulnerable
smb-vuln-ms10-061	Could not negotiate SMB connection — ERROR
samba-vuln-cve-2012-1182	Could not negotiate SMB connection — ERROR

The SMB vulnerability scripts could not fully negotiate a connection, indicating the host may be running a newer SMB dialect (SMBv2/v3) that the older scripts do not support. The ms10-054 script returned false, indicating no vulnerability was detected for that CVE.

1.4 Footprinting (OS and Service Detection)

An aggressive scan was run using `nmap -A 192.168.0.101` to perform OS detection, service version detection, and script scanning. This scan completed in 28.40 seconds.



Attribute	Finding
OS Detected	Microsoft Windows 11 (24H2 – 25H2)
Device Type	General Purpose
OS CPE	cpe:/o:microsoft:windows_11
Network Distance	0 hops
SMB Security Mode	3.1.1 — Message signing enabled and required
SMB2 Time	2026-05-27T00:56:28

Student Reflection (Week 1)

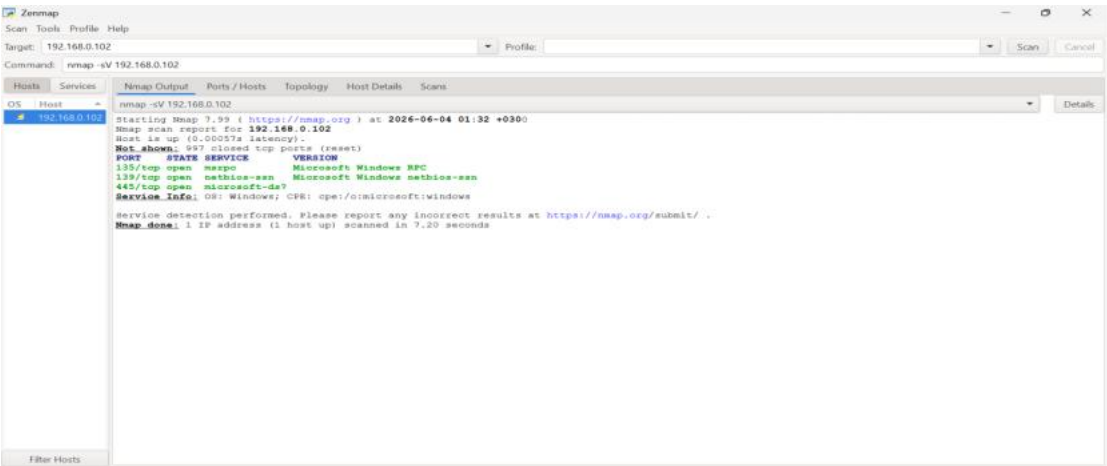
This week introduced Nmap as a core network reconnaissance tool. The open port scan revealed that the target Windows 11 host exposes SMB-related services (ports 135, 139, 445), which are common attack surfaces. The aggressive scan confirmed the OS version and that SMB message signing is enforced — a positive security control. The vulnerability scripts could not negotiate an SMB session, highlighting that modern Windows hosts have improved defences against older exploit techniques.

Week 2: Advanced Nmap Scanning Techniques

Date	May 28, 2026
Tool Used	Nmap (Network Mapper) — Zenmap GUI
Target	192.168.0.101 (Local Network Host)
Objective	Perform advanced Nmap scans: port scanning, OS identification, service detection, user enumeration, and vulnerability detection

2.1 Scan Ports

A targeted port scan was conducted to identify active services running on the host. The scan confirmed the presence of standard Windows networking ports and several high-numbered dynamic ports used by the RPC endpoint mapper.



2.2 Identify OS Version

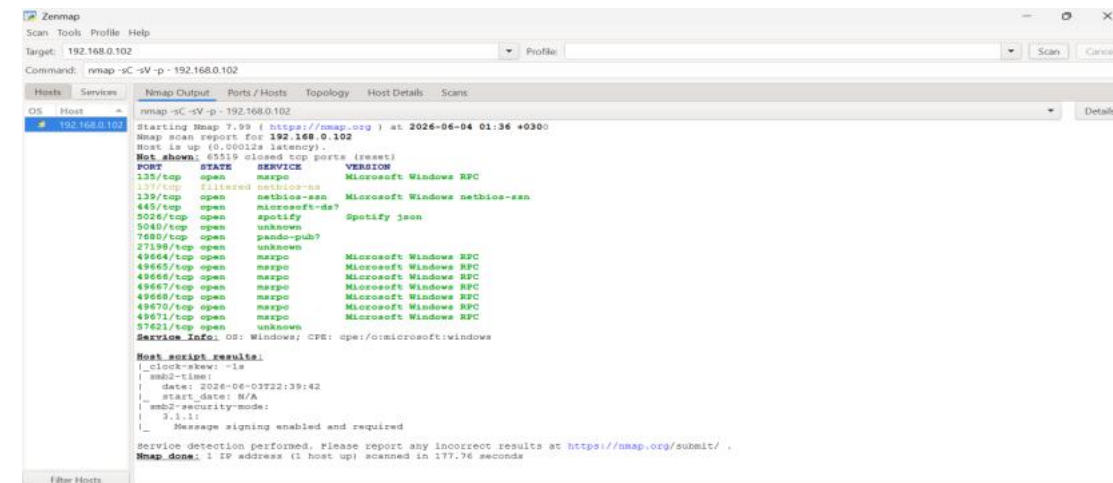
OS version detection was performed as part of the aggressive scan (-A flag) and confirmed via SMB2 protocol negotiation. Nmap detected the host as running Microsoft Windows 11 (versions 24H2 to 25H2) with high confidence.



Detection Method	Result
OS Detection (-O)	Microsoft Windows 11 24H2 – 25H2
CPE String	cpe:/o:microsoft:windows_11
SMB2 Dialect	3.1.1 (confirmed via smb2-time script)
Confidence	High (direct response, 0 hops)

2.3 Detect Running Services

Service and version detection (-sV) was performed alongside OS detection. The following services were positively identified on the target host:



Port	Service	Version / Details
135/tcp	msrpc	Microsoft Windows RPC
139/tcp	netbios-ssn	Microsoft Windows netbios-ssn
445/tcp	microsoft-ds	Microsoft Windows SMB (version uncertain)

2.4 Enumerate Users and Shared Folders

SMB enumeration scripts were used to attempt enumeration of users and shared resources. The Nmap scripting engine (NSE) ran the smb-enum-shares and smb-enum-users scripts against the target.


```

kali@kali:~$ enum4linux -a 192.168.0.2
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) On Wed Jun 3 19:01:48 2020

===== ( Target Information ) =====

Target ..... 192.168.0.2
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, no
ne

===== ( Enumerating Workgroup/Domain on 192.168.0.2 ) =====

[E] Can't find workgroup/domain

===== ( Nbtstat Information for 192.168.0.2 ) =====

Looking up status of 192.168.0.2
No reply from 192.168.0.2

===== ( Session Check on 192.168.0.2 ) =====

[E] Server doesn't allow session using username '', password ''. Aborting for
member of test0.

kali@kali:~$

```

The SMB2-security-mode script revealed:

- SMB dialect: 3.1.1
- Message signing: enabled and required
- Direct user enumeration was not possible as authentication was required and guest access is disabled on the target host — consistent with Windows 11 default hardening

2.5 Detect Vulnerabilities

Vulnerability detection scripts from the Nmap Scripting Engine were executed using `nmap --script vuln`. Scripts targeted common SMB and Windows vulnerabilities.



CVE / Script	Result	Interpretation
ms10-054 (SMB Buffer Overflow)	false	Not vulnerable
ms10-061 (Print Spooler)	SMB negotiate error	Unable to test — SMB dialect mismatch
CVE-2012-1182 (Samba RCE)	SMB negotiate error	Unable to test — not a Samba host

Student Reflection (Week 2)

This week expanded Nmap usage to cover structured reconnaissance: OS fingerprinting, service version detection, SMB enumeration, and CVE-based vulnerability scanning. The target was confirmed as a hardened Windows 11 machine with SMB message signing enforced, guest access disabled, and no detectable legacy SMB vulnerabilities. This demonstrates that newer Windows builds have improved default security postures, and that reconnaissance results must be interpreted carefully rather than treated as definitive exploit opportunities.

Week 3:Passive OSINT Reconnaissance — Safaricom PLC

Date	May 28, 2026
Target Organization	Safaricom PLC
Domain	safaricom.co.ke
Tools Used	OSINT Framework, ViewDNS.info, Shodan.io, Email-Format.com, IntelligenceX, Wappalyzer
Objective	Gather publicly available information about Safaricom's digital footprint using passive OSINT techniques only — no active scanning or unauthorized access

1. Domain and Registra information

Tool Used:ViewDNS.info

OSINT Framework

Search tools

Domain Dossier

domainIQ

Domain Tools Whois

SWITCH Internet Domains Whois Lcd

Whoisology

Whois API

DNStuff

Robtex ID

Domaincrawler.com

MarkMonitor Whois Search

capthub

Website Informer

Whois

Whois APIHub

ViewDNS.info

Only DNS Changes

IPWHOIS

Netbula

Whois Records

Subdomains

Discovery

Certificate Search

PassiveData

Reputation

Domain Blacklists

Typewatching

Analysis

URL Expanders

Change Detection

Website Analyser

DNSSEC

Vulnerabilities

Tools

Report Malicious Sites

Usermapia

Email Address

Cloud Infrastructure

IP to MAC Address

Images / Videos / Data

Google Hacking

Instant Messaging

People Search Engines

Casting

Telephone Numbers

Compliance & Risk Intelligence

Public Records

Business Records

Sanitization

Blacklist Tools / Maps

Search Engines

Online Communities

Zillow

Language Recognition

Mobile OSINT

Dark Web

Information & Media Verification

ViewDNS.info

Domain Name + Whois Records

Open ViewDNS.info

Live Free API Global

DESCRIPTION

Comprehensive DNS lookup and WHOIS service providing detailed DNS records, reverse IP lookups, reverse WHOIS searches, and API access for automated queries.

USAGE CONTEXT

DNS reconnaissance, reverse IP and reverse WHOIS lookups, historical DNS tracking

INPUT → OUTPUT

Domain name, IP address, registrant name/email, nameserver → DNS records, WHOIS information, reverse lookups, IP hosting, historical DNS changes

REPORT AN ISSUE

Dead link Paywalled Incorrect info

WHOIS Information for safaricom.co.ke

Domain Name: safaricom.co.ke
Registry Domain ID: 1403-Kenic
Registrar URL: http://domains.safaricom.co.ke
Updated Date: 2025-10-16T06:36:04Z
Creation Date: 2003-02-12T21:00:00Z
Registry Expiry Date: 2030-12-31T21:00:00Z
Registrar Registration Expiration Date: 2030-12-31T21:00:00Z
Registrar: Safaricom Limited
Registrar Street Address: Safaricom House
P.O. Box 46350 - 001001
Nairobi
Registrar Phone: 0722002222
Registrar Email: ebt-domains@Safaricom.co.ke
Registrar Abuse Contact Email:
Registrar Abuse Contact Phone:
Domain Status: active https://icann.org/epp#active
Name Server: ns4.safaricombusiness.co.ke
Name Server: ns1.safaricombusiness.co.ke
Name Server: ns2.safaricombusiness.co.ke
Name Server: ns3.safaricombusiness.co.ke
DNSSEC: signedDelegation

2. IP Address Discovery

Tool Used:ViewDNS.info

IP history results for 'safaricom.co.ke'.

There are 5 historical IP addresses for this domain.

IP ADDRESS	LOCATION	IP ADDRESS OWNER	LAST SEEN ON THIS IP
45.223.28.17	United States	INCAPSULA	2026-05-31
45.223.18.17	United States	INCAPSULA	2026-05-31
196.201.214.47	Nairobi - Kenya	SAFARICOM-LIMITED	2020-06-10
196.201.213.56	Nairobi - Kenya	SAFARICOM-LIMITED	2016-04-14
196.201.214.47	Nairobi - Kenya	SAFARICOM-LIMITED	2016-04-13

3. Subdomain Discovery

Tool Used:ViewDNS.info

Subdomain	IP Address	Purpose
7s.safaricom.co.ke	197.248.2.35	Rugby/Sports portal
accounts.safaricom.co.ke	45.60.12-20.229 (5 IPs)	Customer accounts portal
adfs.safaricom.co.ke	196.201.213.134	Active Directory Federation Services
admin.partnerworkspace.safaricom.co.ke	10.184.165.4 (Internal)	Partner admin portal
adxdsp-uat.safaricom.co.ke	67.207.80.13	Ad Exchange test environment
afya.safaricom.co.ke	197.248.2.37	Health services portal
agm.safaricom.co.ke	196.201.213.182	Annual General Meeting portal
api.dxlapi.safaricom.co.ke	45.60.13.220 /	DXL API gateway

Subdomain	IP Address	Purpose
	45.60.87.21	
api.partnerworkspace.safaricom.co.ke	10.184.165.4 (Internal)	Partner API endpoint
api.safaricom.co.ke	196.201.214.202	Main public API endpoint
apicctv.safaricom.co.ke	197.248.8.119	CCTV/Surveillance API
appstg.safaricom.co.ke	41.90.220.125	Application staging environment
archive.safaricom.co.ke	196.201.213.112	Archive portal
2fa.safaricom.co.ke	No IP	Two-factor authentication service
abbybot.safaricom.co.ke	No IP	AI chatbot (Abby)
admin.business.safaricom.co.ke	No IP	Business administration portal
admin.county.safaricom.co.ke	No IP	County-level administration portal

4. Open Services

Tool Used:Shodan.io

[Explore](#)
[Downloads](#)
[Pricing](#)

TOTAL RESULTS

898

TOP COUNTRIES

Singapore	796
Kenya	67
Ireland	32
South Africa	2
Netherlands	1
More...	

[View Report](#)
[View on Map](#)
[Advanced Search](#)

Product Spotlight: We've Launched a new API for Fast Vulnerability Lookups. Check out [CVEDB](#)

45.223.137.195

metrixdream.safaricom.co.ke
imperva.com
safaricom.co.ke
bela.coaching.safaricom.co.ke
metrixdreamuat.safaricom.co.ke
Incapsula Inc.
Singapore, Singapore

cdn

SSL Certificate

Issued By:
Common Name:
GlobalSign Atlas R3 DV TLS CA 2026 G1

Issued To:
Common Name:
imperva.com

HTTP/1.1 503 Service Unavailable
Content-Type: text/html
Cache-Control: no-cache, no-store
Connection: close
Content-Length: 713
X-Info: 47-188663453-0 0000 RT(1780517017201 25) q(0 -1 -1 -1) r(0 -1)

45.223.19.7

api.os.mesoko.com
deci-ft02.ngao.safaricom.co.ke
sotismmanagement.safaricom.co.ke
www.di.admin.safaricom.co.ke

cdn

SSL Certificate

Issued By:
Common Name:
GlobalSign Atlas R3 DV TLS CA 2026 G1

Issued To:
Common Name:
imperva.com

HTTP/1.1 503 Service Unavailable
Content-Type: text/html
Cache-Control: no-cache, no-store
Connection: close

TOP ORGANIZATIONS

Incapsula Inc	796
Safaricom Limited	59
Amazon Data Services Ireland Limited	27
SAFARICOM LTD	7
Amazon.com, Inc.	3
More...	

[View Report](#)
[View on Map](#)
[Advanced Search](#)

45.223.21.7

api.os.mesoko.com
deci-ft02.ngao.safaricom.co.ke
sotismmanagement.safaricom.co.ke
www.di.admin.safaricom.co.ke
ew-ft03.ngao.safaricom.co.ke
Incapsula Inc.
Singapore, Singapore

cdn

SSL Certificate

Issued By:
Common Name:
GlobalSign Atlas R3 DV TLS CA 2026 G1

Issued To:
Common Name:
imperva.com

HTTP/1.1 503 Service Unavailable
Content-Type: text/html
Cache-Control: no-cache, no-store
Connection: close
Content-Length: 712
X-Info: 58-413966201-0 0000 RT(1780516812430 530) q(0 -1 -1 -1) r(0 -1)

TOP PRODUCTS

AWS ELB	19
nginx	12
ntpd	3
Apache httpd	2
Cisco PIX sanitized smtpd	2
More...	

[View Report](#)
[View on Map](#)
[Advanced Search](#)

45.223.137.195

metrixdream.safaricom.co.ke
imperva.com
safaricom.co.ke
bela.coaching.safaricom.co.ke
metrixdreamuat.safaricom.co.ke
Incapsula Inc.
Singapore, Singapore

cdn

SSL Certificate

Issued By:
Common Name:
GlobalSign Atlas R3 DV TLS CA 2026 G1

Issued To:
Common Name:
imperva.com

HTTP/1.1 503 Service Unavailable
Content-Type: text/html
Cache-Control: no-cache, no-store
Connection: close
Content-Length: 708
X-Info: 30-28586732-0 0000 RT(1780516011555 22) q(0 -1 -1 -1) r(0 -1)

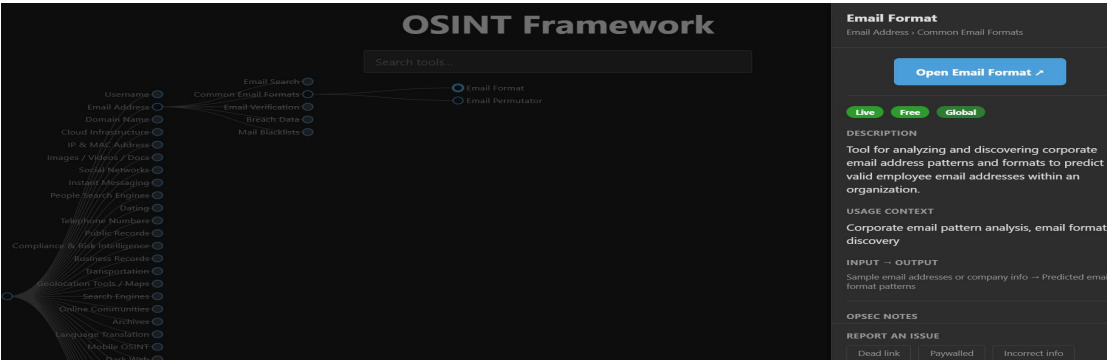
TOP OPERATING SYSTEMS

Ubuntu	2
Windows	2

[View Report](#)
[View on Map](#)
[Advanced Search](#)

5. Email patterns

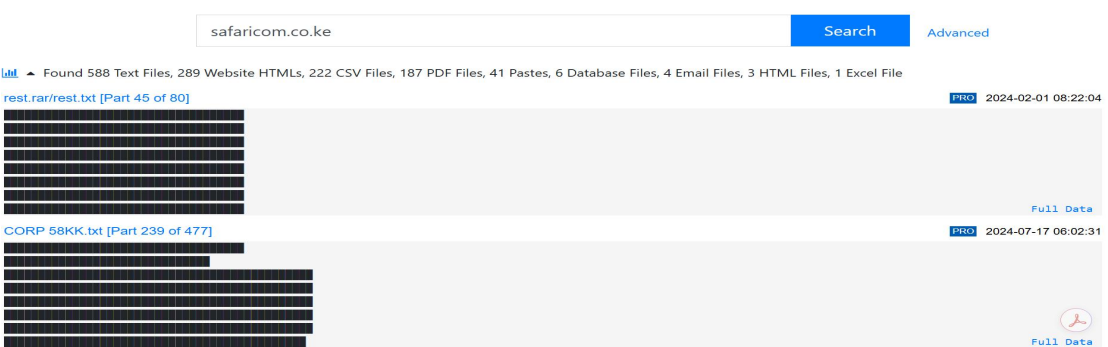
Tool Used:Email Format



Identified Name Formats			Representative Email Addresses	Export to Excel
low confidence				
first_name last_name				
e.g. JohnSmith@safaricom.co.ke				
first_initial last_name				
e.g. JSmith@safaricom.co.ke				
first_name				e.g. John@safaricom.co.ke
last_name				
e.g. Smith@safaricom.co.ke				
last_name first_initial				
e.g. SmithJ@safaricom.co.ke				
first_name last_initial				
e.g. JohnS@safaricom.co.ke				
first_initial - last_name				
e.g. J-Smith@safaricom.co.ke				
first_name - last_name				
e.g. John-Smith@safaricom.co.ke				

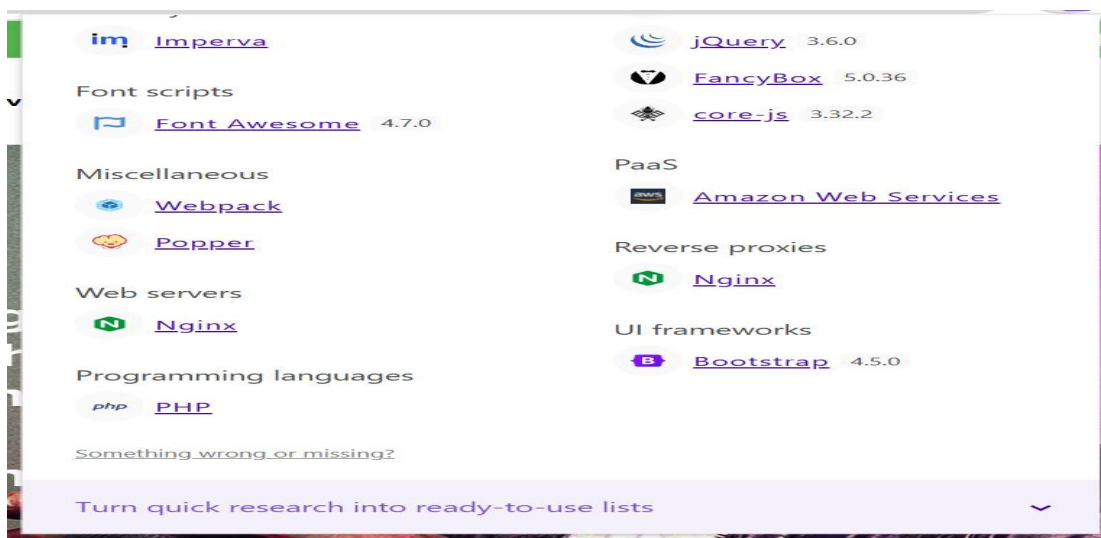
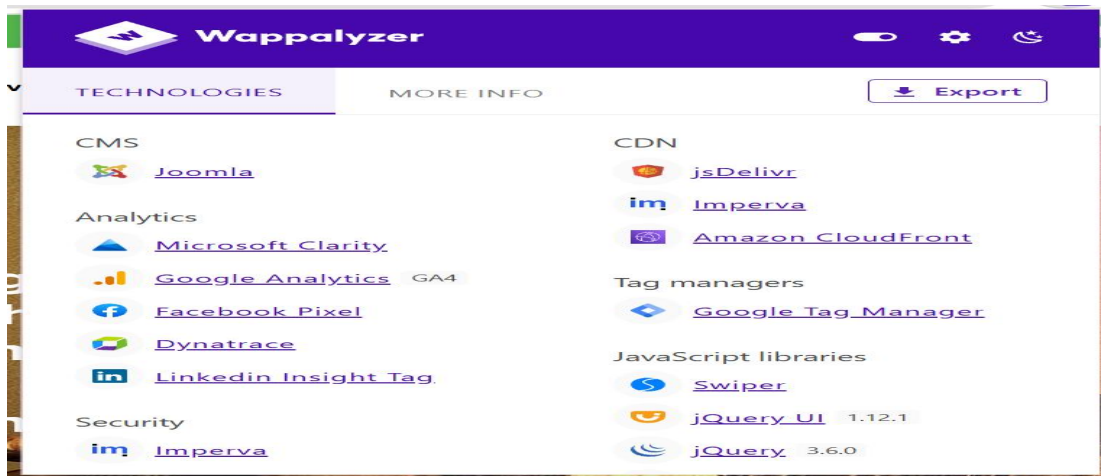
6. Leaked Credentials

Tool Used:Intelx.io



7. Technology

Tool Used:Wappalyzer



Findings and security research

Introduction

This report documents the findings of a passive Open Source Intelligence (OSINT) reconnaissance exercise conducted on Safaricom PLC, Kenya's largest telecommunications company. The purpose of this exercise is to demonstrate how publicly available information can be systematically gathered and analysed to understand an organization's digital footprint without performing any active scanning or unauthorized access.

All information in this report was obtained from publicly accessible tools and databases. No active scanning, exploitation, or intrusion of any kind was performed. The exercise was conducted strictly for academic purposes as part of the Ethical Hacking and Countermeasures course.

Organization Overview

Safaricom PLC is a Kenyan telecommunications company and the largest mobile network operator in Kenya. It is best known for its M-PESA mobile money service, which has become one of the most widely used financial services platforms in Africa. The company operates under the domain safaricom.co.ke and offers services including mobile telephony, mobile internet, cloud solutions, and IoT services.

Attribute	Details
Company Name	Safaricom PLC
Industry	Telecommunications
Country	Kenya
Primary Domain	safaricom.co.ke
Notable Services	M-PESA, Safaricom Fiber, Safaricom Business, IoT Solutions

Summary of Findings

Task	Tool Used	Key Finding
Domain Information	ViewDNS.info Whois	Self-registered by Safaricom, active since 2003, expires 2030
Registrar	ViewDNS.info Whois	Safaricom Limited manages their own domain
IP Address	ViewDNS.info IP History	Currently behind Imperva WAF; origin IP is hidden
Subdomain Discovery	ViewDNS.info Subdomains	17+ subdomains found including internal IP address leaks
Open Services	Shodan.io	898 indexed results; FortiGate firewall nodes visible
Email Patterns	Email-Format.com	8 patterns identified, all with low confidence
Leaked Credentials	IntelligenceX	1,341 files referencing the domain found in breach databases
Technology Stack	Wappalyzer	Joomla/PHP/Nginx on AWS; several outdated JS libraries

1. Domain and Registrar Information

The first step in the reconnaissance was to gather domain and registrar information using the Whois lookup tool on ViewDNS.info. This tool queries public Whois databases which are maintained by domain registrars and provide registration details for any domain name.

Field	Finding
Domain Name	safaricom.co.ke
Registry Domain ID	1403-Kenic
Registrar	Safaricom Limited (Self-Registered)
Registrar URL	http://domains.safaricom.co.ke
Registrar Address	Safaricom House, P.O. Box 46350-001001, Nairobi
Registrar Phone	0722002222
Registrar Email	ebt-domains@Safaricom.co.ke
Creation Date	February 12, 2003
Last Updated	October 16, 2025
Expiry Date	December 31, 2030
Domain Status	Active
DNSSEC	Signed Delegation (Enabled)
Name Servers	ns1, ns2, ns3, ns4.safaricombusiness.co.ke

Observations

- Safaricom acts as its own domain registrar, meaning the company manages its own domain registration directly rather than going through a third-party registrar.
- The domain has been active since February 2003, indicating over 20 years of continuous operation.
- DNSSEC (Domain Name System Security Extensions) is enabled. This means DNS responses are cryptographically signed, which protects against DNS spoofing and cache poisoning attacks.
- The company uses four name servers all under safaricombusiness.co.ke, which suggests a deliberate separation between their public website infrastructure and their business/corporate DNS infrastructure.
- The domain is registered until December 2030, showing long-term planning and no immediate risk of domain expiry.

2. IP Address Information

The IP history lookup on ViewDNS.info was used to retrieve both the current and historical IP addresses associated with safaricom.co.ke. This helps to understand the hosting history and current infrastructure of the organization.

IP Address	Location	Owner	Last Seen
------------	----------	-------	-----------

IP Address	Location	Owner	Last Seen
45.223.28.17	United States	INCAPSULA (Imperva)	2026-05-31
45.223.18.17	United States	INCAPSULA (Imperva)	2026-05-31
196.201.214.47	Nairobi, Kenya	SAFARICOM-LIMITED	2020-06-10
196.201.213.56	Nairobi, Kenya	SAFARICOM-LIMITED	2016-04-14
196.201.214.47	Nairobi, Kenya	SAFARICOM-LIMITED	2016-04-13

Observations

- The current IP addresses resolve to INCAPSULA, which is a product of Imperva — a cloud-based Web Application Firewall (WAF) and DDoS protection service. This means the actual origin server IP is hidden behind a reverse proxy, making it difficult for attackers to target the real server directly.
- The IP addresses are registered in the United States even though Safaricom is a Kenyan company. This is because Imperva operates global CDN nodes and routes traffic through their international infrastructure.
- Between 2003 and approximately 2020, Safaricom hosted their website on their own infrastructure in Nairobi, Kenya, as seen from the historical IP addresses in the 196.201.x.x range which are owned by SAFARICOM-LIMITED.
- The migration to cloud-based WAF protection represents a significant improvement in the organization's security posture.

3. Subdomain Discovery

Subdomain discovery was performed using the Subdomain Discovery tool on ViewDNS.info. Identifying subdomains helps to map out the full scope of an organization's online presence and can reveal internal systems or sensitive services that are publicly accessible.

Subdomain	IP Address	Purpose
7s.safaricom.co.ke	197.248.2.35	Rugby/Sports portal
accounts.safaricom.co.ke	45.60.12-20.229 (5 IPs)	Customer accounts portal
adfs.safaricom.co.ke	196.201.213.134	Active Directory Federation Services
admin.partnerworkspace.safaricom.co.ke	10.184.165.4 (Internal)	Partner admin portal
adxdsp-uat.safaricom.co.ke	67.207.80.13	Ad Exchange test environment

Subdomain	IP Address	Purpose
afya.safaricom.co.ke	197.248.2.37	Health services portal
agm.safaricom.co.ke	196.201.213.182	Annual General Meeting portal
api.dxlapi.safaricom.co.ke	45.60.13.220 / 45.60.87.21	DXL API gateway
api.partnerworkspace.safaricom.co.ke	10.184.165.4 (Internal)	Partner API endpoint
api.safaricom.co.ke	196.201.214.202	Main public API endpoint
apicctv.safaricom.co.ke	197.248.8.119	CCTV/Surveillance API
appstg.safaricom.co.ke	41.90.220.125	Application staging environment
archive.safaricom.co.ke	196.201.213.112	Archive portal
2fa.safaricom.co.ke	No IP	Two-factor authentication service
abbybot.safaricom.co.ke	No IP	AI chatbot (Abby)
admin.business.safaricom.co.ke	No IP	Business administration portal
admin.county.safaricom.co.ke	No IP	County-level administration portal

Observations

- Two subdomains — admin.partnerworkspace and api.partnerworkspace — resolve to the IP address 10.184.165.4, which is a private RFC1918 IP address. This is an information disclosure vulnerability because private IP addresses should never appear in public DNS records. It reveals details about the internal network structure of Safaricom.
- The presence of adxdsp-uat and appstg subdomains indicates that test and staging environments are publicly accessible. These environments often have weaker security controls than production systems and could be a potential attack vector.
- The subdomain adfs.safaricom.co.ke reveals that the organization uses Microsoft Active Directory Federation Services, which tells us about their internal identity and authentication infrastructure.
- The subdomain apicctv.safaricom.co.ke reveals that Safaricom operates a dedicated API for CCTV and surveillance infrastructure, which is sensitive information.
- The accounts subdomain uses five different IP addresses for load balancing, indicating that the customer portal is designed for high availability.

4. Open Services

Shodan.io was used to identify open services and exposed infrastructure. Shodan is a search engine that indexes information about internet-connected devices and services. The search query used was `hostname:safaricom.co.ke`.

Field	Finding
Total Results	898 hosts/services indexed
Primary WAF/CDN	Incapsula Inc (Imperva)
Servers in Singapore	796
Servers in Kenya	67
Servers in Ireland	32
Other locations	South Africa (2), Netherlands (1)
SSL Certificate Issuer	GlobalSign Atlas R3 DV TLS CA 2026 Q1
HTTP Response from WAF	503 Service Unavailable

Additional Subdomains Found via Shodan

Subdomain	Significance
metricstream.safaricom.co.ke	Risk and compliance management system
safaricomcms.safaricom.co.ke	Content Management System
iotsimmanagement.safaricom.co.ke	IoT SIM card management platform
beta.coaching.safaricom.co.ke	Beta coaching/training portal
deci-fgt02.ngao.safaricom.co.ke	FortiGate firewall node
ew-fgt03.ngao.safaricom.co.ke	FortiGate firewall node

Observations

- Shodan returned 898 results, indicating that Safaricom has a large attack surface with many publicly visible services and hosts.
- The majority of servers (796 out of 898) are located in Singapore and are part of Imperva's global CDN/WAF network, which is consistent with the IP history findings.
- The WAF is configured to return HTTP 503 errors to automated scanners, which shows that Safaricom has active countermeasures against reconnaissance activities.
- The FortiGate firewall hostnames (fgt02 and fgt03) are visible in public DNS. While the devices themselves may not be directly accessible, revealing the type of firewall in use is an information disclosure that could assist an attacker in planning an attack.
- The IoT SIM management subdomain being publicly resolvable is significant given that Safaricom runs a large IoT business division.

5. Email Patterns

Email-Format.com was used as a free alternative to Hunter.io to identify the email naming conventions used by Safaricom employees. Understanding email patterns is relevant in social engineering and phishing simulations during authorized penetration tests.

Pattern Format	Example	Confidence Level
first_name last_name	JohnSmith@safaricom.co.ke	Low-Medium
first_initial last_name	JSmith@safaricom.co.ke	Low
first_name only	John@safaricom.co.ke	Low
last_name only	Smith@safaricom.co.ke	Low
last_name first_initial	SmithJ@safaricom.co.ke	Low
first_name last_initial	JohnS@safaricom.co.ke	Low
first_initial-last_name	J-Smith@safaricom.co.ke	Very Low
first_name-last_name	John-Smith@safaricom.co.ke	Very Low

Observations

- All patterns were returned with low confidence, meaning the tool could not find enough publicly available Safaricom email addresses to confirm which pattern is the primary one in use.
- In most corporate organizations the most commonly used pattern is firstname.lastname@domain, which was not listed here but remains the most probable pattern based on general industry norms.
- Knowledge of the email format is used in ethical hacking engagements for crafting realistic phishing simulations and verifying credential lists during authorized assessments.

6. Leaked Credentials

IntelligenceX (intelx.io) was used to search for any leaked or publicly exposed data associated with the safaricom.co.ke domain. IntelligenceX is a search engine that indexes data from paste sites, breach databases, and other public sources.

File Type	Count
Text Files (.txt)	588
Website HTML Files	289
CSV Files	222

File Type	Count
PDF Files	187
Pastes	41
Database Files	6
Email Files	4
HTML Files	3
Excel Files	1
Total	1,341 files

Notable Files Observed

Filename	Date	Note
rest.rar/rest.txt [Part 45 of 80]	2024-02-01	Part of an 80-part archive dump
CORP 58KK.txt [Part 239 of 477]	2024-07-17	Part of a 477-part corporate data dump

Observations

- A total of 1,341 files referencing safaricom.co.ke were indexed across breach and paste databases, which is a significant number and indicates that the organization has been included in multiple data dumps.
- The 6 database files are of particular concern as they are likely to contain structured data such as user records, email addresses, or credentials.
- The 222 CSV files could contain exported data such as employee lists, customer records, or transaction logs.
- The file names such as CORP 58KK.txt and rest.rar suggest large-scale corporate data dumps from 2024.
- The actual contents of these files were not accessible without a paid IntelligenceX subscription. Therefore, the exact nature of the exposed data could not be confirmed in this exercise.

7. Technology Stack

The Wappalyzer browser extension was used to identify the technologies running on the Safaricom website. Wappalyzer detects technologies by analysing HTTP response headers, HTML source code, and JavaScript variables.

Category	Technology	Version
CMS	Joomla	Not detected

Category	Technology	Version
Programming Language	PHP	Server-side
Web Server	Nginx	Web server and reverse proxy
Cloud Platform	Amazon Web Services (AWS)	PaaS hosting
CDN	Amazon CloudFront	Content delivery
CDN	jsDelivr	JavaScript library delivery
WAF / CDN	Imperva	DDoS protection and security
Analytics	Google Analytics	GA4
Analytics	Microsoft Clarity	Session recording
Analytics	Dynatrace	Performance monitoring
Ad Tracking	Facebook Pixel	Facebook advertising
Ad Tracking	LinkedIn Insight Tag	LinkedIn advertising
Tag Management	Google Tag Manager	Tag management
JavaScript Library	jQuery	3.6.0
JavaScript Library	jQuery UI	1.12.1
JavaScript Library	Fancybox	5.0.36
JavaScript Library	core-js	3.32.2
JavaScript Library	Swiper	Not detected
JavaScript Library	Webpack	Not detected
JavaScript Library	Popper	Not detected
UI Framework	Bootstrap	4.5.0
Font Library	Font Awesome	4.7.0

Observations

- The website is built on Joomla CMS using PHP as the server-side programming language. Joomla is a well-known CMS that has historically been a frequent target for attackers, making it important for the organization to keep it updated.
- jQuery version 3.6.0 and jQuery UI version 1.12.1 are relatively outdated. Older versions of these libraries are known to carry security vulnerabilities that could be exploited if not patched.
- Bootstrap 4.5.0 is an older version — the current major version is Bootstrap 5. Similarly, Font Awesome 4.7.0 is significantly outdated compared to the current version 6.x.

- The organization uses five different analytics and tracking tools, which indicates extensive monitoring of user behaviour on the website.
- The presence of Imperva as both a CDN and WAF provider is consistent with findings from the IP history and Shodan analysis.

8. Security Recommendations

Based on the findings of this OSINT exercise, the following recommendations are made to improve the security posture of the organization.

i. DNS Hygiene

- The internal IP addresses found in public DNS records (10.184.165.4) should be removed or replaced with public-facing addresses. Internal IP addresses should never be exposed in public DNS as they reveal internal network topology.
- UAT and staging subdomains such as adxdsp-uat and appstg should be removed from public DNS or restricted to internal access only.

ii. Software Updates

- The jQuery and jQuery UI libraries should be updated to their latest versions to address any known security vulnerabilities.
- Bootstrap and Font Awesome should also be updated to their current major versions.
- Joomla CMS should be kept up to date with all security patches applied promptly.

iii. Data Breach Response

- The organization should conduct a thorough investigation into the 1,341 files indexed on IntelligenceX. A paid subscription or engagement with a cybersecurity firm may be needed to review the actual contents of these files.
- If any valid credentials are found in the breach data, those accounts should be disabled and affected users notified.

iv. Ongoing Monitoring

- The organization should implement continuous monitoring using tools like Shodan and IntelligenceX to detect new exposures as they occur.
- A regular OSINT assessment should be conducted at least annually as part of the organization's security programme.

Conclusion

This exercise demonstrated that a significant amount of information about Safaricom PLC is publicly available through passive OSINT techniques. Using only free and publicly accessible tools, it was possible to identify the domain registrar, historical and current IP addresses, over 17 subdomains, 898 indexed hosts on Shodan, email naming patterns, evidence of data exposure in breach databases, and the full technology stack of the website.

Several notable findings were made including the exposure of internal IP addresses in public DNS, the visibility of FortiGate firewall hostnames, the presence of staging environments accessible from the internet, and the indexing of over 1,300 files in breach databases. These findings highlight the importance of regular OSINT assessments as part of an organization's security programme.

It is important to emphasize that all information gathered was obtained from publicly available sources only. No active scanning, exploitation, or unauthorized access was performed at any point during this exercise.